

Informe: Implementación de Políticas de Seguridad DLP

Cliente / Entidad Target: TechCorp Inc. / 4GEEKS

Tipo de Informe: Generación de políticas

Fecha de Emisión: 11 de Septiembre de 2026

1. Introducción	2
2. Clasificación de la Información en Función de su Sensibilidad	4
3. Políticas de Control de Acceso basadas en el Principio del Menor Privilegio	6
4. Reglas para el Monitoreo de Datos Sensibles y Auditoría de Actividades	9
5. Prevención de Filtraciones de Datos Sensibles	13
6. Programa de Educación y Concienciación en Ciberseguridad	16

1. Introducción

1.1. Contexto Organizacional y Propósito

TechCorp Inc. es una empresa de desarrollo de software personalizado que opera para sectores altamente regulados como finanzas, atención médica y comercio electrónico, respaldada por un equipo de 200 empleados. Dada la naturaleza de sus operaciones, la protección de los datos de sus clientes y colaboradores resulta fundamental para mantener los más altos estándares de calidad, el cumplimiento normativo y la continuidad del negocio. El propósito de esta sección es definir el marco conceptual de la Prevención de Pérdida de Datos (DLP) y resaltar su importancia estratégica en la custodia de los activos de información confidencial de la organización.

1.2. Concepto General de DLP y Estados de la Información

La Prevención de Pérdida de Datos (DLP, por sus siglas en inglés *Data Loss Prevention*) abarca un conjunto clave de estrategias y tecnologías de ciberseguridad orientadas a prevenir el acceso no autorizado, el robo de datos y la exposición indebida de información sensible. Para garantizar una cobertura integral, las soluciones de DLP abordan la seguridad de los datos según los tres estados en los que habita la información dentro de la infraestructura tecnológica:

- **Datos en Reposo:** Corresponde a la información almacenada que no se encuentra en procesamiento activo ni en transmisión, como archivos en discos duros, bases de datos y almacenamiento en la nube. En el contexto de TechCorp, esto abarca contratos de empleados, expedientes de Recursos Humanos, presupuestos de Finanzas y la propiedad intelectual custodiada por el área de Investigación y Desarrollo.
- **Datos en Movimiento:** Se refiere a los datos que se están transmitiendo activamente a través de la red corporativa o redes externas mediante correo electrónico, aplicaciones web o transferencias de archivos. Incluye el intercambio de información con actores externos, como contratos de servicios, datos de facturación con proveedores y comunicaciones comerciales con clientes.
- **Datos en Uso:** Hace referencia a la información que está siendo procesada, consultada o manipulada activamente por un usuario o aplicación, manteniéndose en la memoria RAM, la caché de la CPU o mostrada en pantalla. Esto se evidencia durante la atención y gestión de tickets de Soporte al Cliente o la programación activa de soluciones de software en I+D.

1.3. Importancia Estratégica dentro de la Organización

La implementación de un marco DLP dentro de TechCorp es crítica para salvaguardar la confidencialidad, la integridad y el cumplimiento de estándares

internacionales como el GDPR. Las tecnologías y políticas DLP actúan como un escudo protector frente a brechas de seguridad accidentales o maliciosas, resguardando la ventaja competitiva de la empresa, la privacidad de los colaboradores y la confianza depositada por nuestros clientes. En consecuencia, el DLP establece un estándar operativo que fortalece la cultura organizacional y asegura la protección de los datos en todas las fases del ciclo de vida de la información.

2. Clasificación de la Información en Función de su Sensibilidad

2.1. Criterios de Clasificación Organizacional

La clasificación de datos es el proceso de categorizar la información en función de su nivel de sensibilidad e importancia para la organización. En TechCorp Inc., este procedimiento permite aplicar medidas de ciberseguridad, controles de acceso y políticas de protección diferenciadas según el impacto que tendría la exposición o el uso no autorizado de cada activo de datos. La estructura organizativa abarca cinco departamentos clave (Recursos Humanos, Finanzas, Investigación y Desarrollo, Soporte al Cliente, y Ventas y Marketing), los cuales gestionan un inventario de 25 tipos de datos clasificados estrictamente en tres categorías.

2.2. Categorías de Clasificación y Distribución de Activos

A. Alta Sensibilidad

Comprende la información crítica cuyo compromiso, robo, extracción o acceso no autorizado representaría un impacto grave para la privacidad legal, la propiedad intelectual o la estabilidad financiera de TechCorp Inc..

Los activos asignados a esta categoría corresponden a:

- Recursos Humanos: Contrato de cada empleado, información familiar del empleado e historial de resolución de conflictos.
- Finanzas: Historial de pago de empleados, historial de facturación, historial de cobranzas y contratos de servicios a clientes.
- Investigación y Desarrollo (I+D): Historial de productos desarrollados y laboratorio de innovación.
- Ventas y Marketing: Información de contacto de clientes, información específica para relacionarse con clientes y lista de proyectos de clientes.

B. Media Sensibilidad

Agrupar información interna de carácter operativo y táctico requerida para la gestión del negocio, cuyo acceso debe estar controlado y restringido únicamente al personal involucrado en sus respectivos procesos.

Los activos asignados a esta categoría corresponden a:

- Recursos Humanos: Información médica de cada empleado e informes de rendimiento.
- Finanzas: Planificación financiera de la empresa (presupuesto).
- Investigación y Desarrollo (I+D): Data de productos en desarrollo e investigaciones de mercado.
- Soporte al cliente: Lista de clientes, historial de consultas e historial de satisfacción.
- Ventas y Marketing: Estudio de mercado e historial de campañas.

C. Baja Sensibilidad

Incluye información operativa de carácter general o de uso técnico cotidiano cuyo riesgo asociado a la divulgación interna es mínimo, permitiendo un manejo más flexible dentro de la infraestructura.

Los activos asignados a esta categoría corresponden a:

- Investigación y Desarrollo (I+D): Información de tecnologías emergentes.
- Soporte al Cliente: Historial de sugerencias de mejora e historial de escalamiento.

3. Políticas de Control de Acceso basadas en el Principio del Menor Privilegio

3.1. Aplicación del Principio del Menor Privilegio (PoLP)

El Principio del Menor Privilegio (PoLP, por sus siglas en inglés *Principle of Least Privilege*) establece que a cada usuario, proceso o sistema se le deben otorgar únicamente los permisos y accesos estrictamente necesarios para desempeñar sus funciones operativas asignadas.

En TechCorp Inc., la implementación de este principio evita la concesión de accesos generalizados entre sus 200 empleados, aislando el acceso a la información confidencial de los cinco departamentos de la empresa (Recursos Humanos, Finanzas, Investigación y Desarrollo, Soporte al Cliente, y Ventas y Marketing). La arquitectura de acceso se fundamenta en un modelo de Control de Acceso Basado en Roles (RBAC) gestionado a través de soluciones de identidad centralizadas como Active Directory, Azure AD, IAM de AWS u Okta.

3.2. Políticas de Acceso según la Sensibilidad de los Datos

A. Políticas para Datos de Alta Sensibilidad (● ALTO)

- **Regla de Acceso:** El acceso está restringido por defecto y solo se otorga de manera nominativa e individualizada al personal del departamento generador del activo que requiera consultar o modificar la información para cumplir sus tareas diarias.
- **Controles Obligatorios:**
 - Requisito estricto de Autenticación Multifactor (MFA) para todos los inicios de sesión.
 - Nivel de autorización granular configurado en los directorios de identidad.
 - Prohibición explícita de compartir credenciales o carpetas de acceso general.
- **Aplicación en TechCorp Inc.:** Los contratos de empleados, la información familiar y el historial de conflictos sólo son accesibles por personal autorizado de Recursos Humanos. Los historiales de pago, facturación, cobranzas y contratos de clientes están restringidos al equipo de Finanzas. El laboratorio de innovación y el historial de productos en I+D permanecen aislados exclusivamente para los desarrolladores asignados al proyecto.

B. Políticas para Datos de Media Sensibilidad (● MEDIO)

- **Regla de Acceso:** Se otorga acceso basado en el rol operativo dentro del departamento correspondiente, permitiendo la lectura o edición técnica de los archivos necesarios para la continuidad del negocio.
- **Controles Obligatorios:**

- Autenticación mediante credenciales corporativas con inicio de sesión único (SSO) y MFA.
 - Asignación de permisos de solo lectura para roles de supervisión o colaboración interdepartamental.
 - Aplicación en TechCorp Inc.: La lista de clientes e historial de consultas son accesibles por los operadores de Soporte al Cliente para la resolución de tickets. La planificación financiera (presupuestos) y los datos de productos en desarrollo están limitados a los perfiles de gestión en Finanzas, I+D y Ventas.
- C. Políticas para Datos de Baja Sensibilidad (● BAJO)
- Regla de Acceso: Permisos de acceso y lectura extendidos para los miembros de los departamentos operativos, facilitando el intercambio de conocimientos y la resolución ágil de problemas.
 - Controles Obligatorios:
 - Autenticación estándar de usuario dentro de la red corporativa o dominio.
 - Registro de auditoría básico para evitar la alteración no autorizada de la información.
 - Aplicación en TechCorp Inc.: La información de tecnologías emergentes en I+D y los historiales de sugerencias de mejora o escalamiento en Soporte al Cliente están disponibles para los equipos técnicos para impulsar la innovación y la mejora continua del servicio.

3.3. Flujo y Roles Responsables de la Revisión de Permisos

Para evitar la acumulación no autorizada de privilegios (*permission creep*) y garantizar que los accesos se mantengan alineados con las necesidades reales del negocio, se establece un flujo estructurado de revisión y auditoría periódica.

[Solicitud / Cambio de Rol] → [Aprobación del Jefe Departamental] → [Aprovisionamiento por TI/CISO] → [Auditoría Trimestral]

A. Roles Responsables de la Gestión de Acceso

- Líderes / Jefes de Departamento (HR, Finanzas, I+D, Soporte, Ventas): Son los Propietarios de los Datos (Data Owners). Tienen la responsabilidad de validar, aprobar o rechazar formalmente las solicitudes de acceso a la información de sus respectivas áreas, así como de certificar las revisiones periódicas de su personal.
- Administradores de TI / Oficial de Seguridad (CISO): Actúan como los Custodios de los Datos (Data Custodians). Son responsables de ejecutar técnicamente el aprovisionamiento o revocación de permisos en Active Directory, Azure AD o IAM de AWS, asegurando la configuración de políticas DLP y la auditoría del sistema.

B. Procedimiento y Flujo de Revisión de Permisos

- Aprovisionamiento Inicial y Modificaciones de Rol:
 - Toda solicitud de nuevo acceso debe ser tramitada mediante un ticket formal que justifique la necesidad operativa.

- Requiere la aprobación explícita del Jefe de Departamento antes de que el equipo de TI proceda con la asignación en los sistemas.
- Revisiones Periódicas de Permisos (Auditorías Trimestrales):
 - Generación de Informes: El área de TI/CISO extrae de forma trimestral los reportes completos de usuarios, roles y permisos activos utilizando las capacidades de auditoría de Active Directory, Azure AD, Okta o IAM.
 - Evaluación Departamental: Cada Jefe de Departamento analiza la lista de accesos de su equipo para verificar que cada empleado mantenga únicamente los permisos necesarios para su puesto actual.
 - Depuración de Accesos: Si se detectan privilegios obsoletos o excesivos, el Jefe de Departamento solicita de inmediato la revocación o ajuste de permisos al área de TI.
- Desaprovisionamiento Inmediato (Offboarding y Transiciones):
 - En caso de desvinculación laboral, el departamento de Recursos Humanos notifica automáticamente al área de TI para proceder con el bloqueo e inhabilitación inmediata de todas las cuentas y accesos del usuario.
 - En caso de traslado interno o cambio de puesto, se revocan los permisos del rol anterior antes de asignar los correspondientes a la nueva función.

4. Reglas para el Monitoreo de Datos Sensibles y Auditoría de Actividades

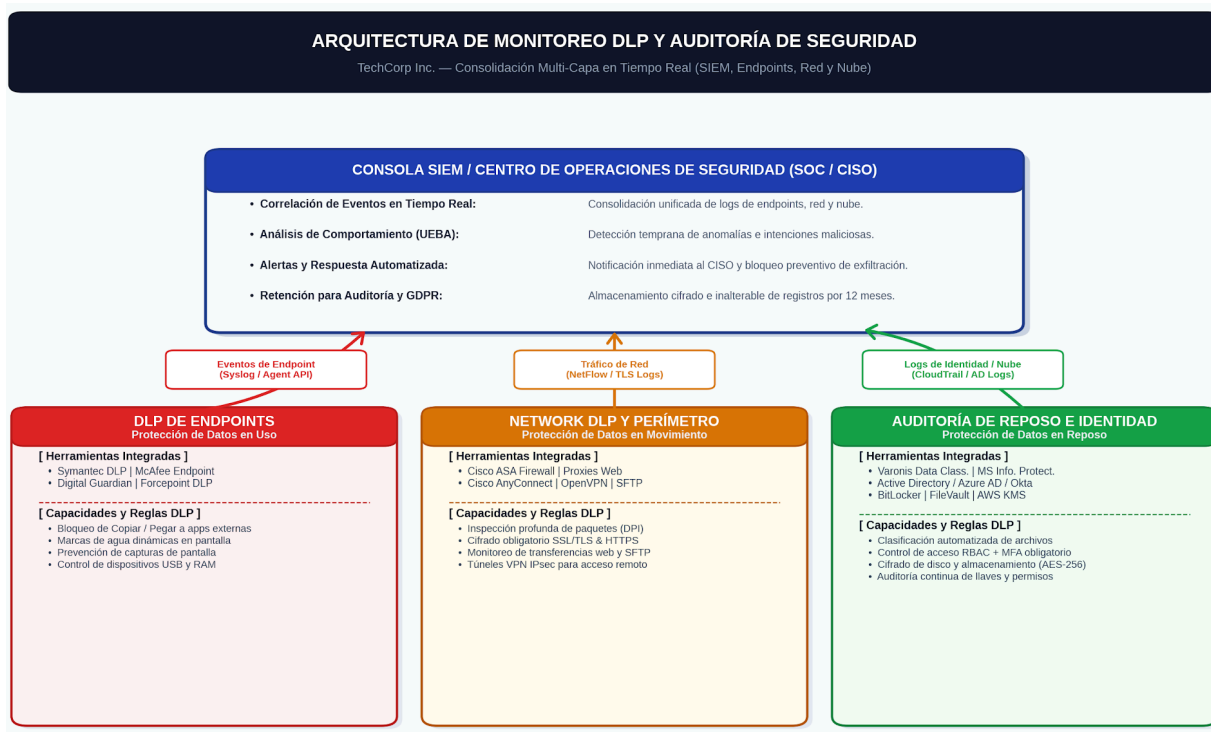
4.1. Reglas Generales de Monitoreo y Auditoría

El monitoreo y la auditoría de actividades son componentes esenciales para detectar accesos no autorizados, prevenir la fuga de datos y garantizar el cumplimiento normativo dentro de TechCorp Inc.. Con una fuerza laboral de 200 empleados que interactúan con sectores regulados, la organización debe establecer directrices obligatorias para la supervisión continua del uso de la información en la infraestructura local y en la nube:

- **Monitoreo Continuo y en Tiempo Real:** Toda actividad que involucre activos de información clasificados como de Alta y Media sensibilidad debe ser supervisada en tiempo real mediante herramientas automatizadas.
- **Inalterabilidad y Trazabilidad de Registros (Logs):** Todos los eventos de acceso, modificación, lectura, descarga, copia y transferencia de datos sensibles deben generar un registro de auditoría completo. Queda estrictamente prohibida la modificación o eliminación manual de estos registros.
- **Intervención y Alertas Automáticas:** Las soluciones de supervisión deben estar configuradas para alertar de inmediato al equipo de TI/CISO o bloquear la acción en tiempo real cuando se detecte un comportamiento anómalo o una violación de las políticas de seguridad.
- **Protección de la Privacidad del Usuario:** El monitoreo se limitará exclusivamente a las actividades laborales y al tráfico que contenga o interactúe con datos corporativos, manteniendo el cumplimiento con marcos de privacidad como el GDPR.

4.2. Herramientas Especializadas de Monitoreo y Auditoría

Para cubrir los tres estados de la información (reposo, movimiento y uso), TechCorp Inc. utilizará una arquitectura multicapa de soluciones tecnológicas avanzadas:



1. Monitoreo de Datos en Uso (Agentes de Endpoint DLP)

Para proteger la información mientras está siendo procesada, editada o visualizada, se desplegarán agentes de software especializados en los dispositivos individuales de los empleados. Estos agentes funcionan como centinelas locales que rastrean el comportamiento del usuario en tiempo real:

- Soluciones Sugeridas: Symantec DLP, McAfee DLP Endpoint, Digital Guardian o Forcepoint DLP.
- Capacidades de Monitoreo:
 - Bloqueo y registro de operaciones de copiar y pegar datos confidenciales hacia aplicaciones no corporativas.
 - Restricción y auditoría de la captura de pantalla e inserción de marcas de agua dinámicas en aplicaciones que desplieguen propiedad intelectual de I+D o historiales de clientes.
 - Control de transferencias hacia dispositivos de almacenamiento extraíbles (USBs) y escaneo de memoria RAM contra análisis de comportamiento anómalo.
 - Capacidad de intervención directa: emisión de advertencias al usuario o bloqueo inmediato del evento.

2. Monitoreo de Datos en Movimiento (Network DLP y Perímetro)

Para la supervisión de los datos que se transmiten a través de la red corporativa, canales web o conexiones externas:

- Soluciones Sugeridas: Puertas de enlace de red (Network DLP) integradas con firewalls de red como Cisco ASA, servidores proxy y clientes VPN como Cisco AnyConnect o OpenVPN.

- Capacidades de Monitoreo:
 - Inspección profunda de paquetes y filtrado de contenido en los puntos de entrada y salida de la red.
 - Auditoría de transferencias de archivos mediante protocolos seguros como SFTP (WinSCP) y cifrado SSL/TLS / HTTPS.
 - Detección y bloqueo de envíos no autorizados de contratos, listados de proyectos o facturas hacia direcciones de correo no verificadas.

3. Auditoría de Datos en Reposo e Identidad

Para auditar la información almacenada en servidores locales, bases de datos y servicios en la nube:

- Soluciones Sugeridas: Varonis Data Classification Engine, Microsoft Information Protection, Azure AD, Okta, IAM de AWS y AWS Key Management Service (AWS KMS).
- Capacidades de Monitoreo:
 - Varonis y Microsoft Information Protection: Escaneo continuo y análisis de comportamiento sobre archivos estructurados y no estructurados, registrando quién accede, edita o cambia los permisos de archivos sensibles.
 - Azure AD / Okta / AWS IAM: Generación de informes completos de auditoría sobre intentos de inicio de sesión, uso de Inicio de Sesión Único (SSO), autenticación multifactor (MFA) y cambios en la asignación de roles.
 - AWS KMS: Registros detallados de la rotación y uso de claves de cifrado en la nube.

D. Integración Centralizada en un Sistema SIEM (Gestión de Eventos e Información de Seguridad)

Para consolidar la visibilidad de toda la infraestructura tecnológica de TechCorp Inc. (endpoints, red, nube y aplicaciones corporativas), todos los logs generados por los agentes DLP, firewalls y plataformas de identidad se canalizarán hacia una solución SIEM centralizada.

- Función del SIEM: Correlacionar eventos en tiempo real (por ejemplo, detectar si un usuario descarga un volumen atípico de archivos de I+D y simultáneamente intenta conectarse a un servidor SFTP externo).
- Análisis de Comportamiento (UEBA): Analizar desviaciones en el comportamiento habitual de los empleados para identificar posibles amenazas internas o credenciales comprometidas.

4.3. Procedimiento de Auditoría y Retención de Registros

- Revisión Diaria de Alertas: El equipo de operaciones de seguridad (SOC/TI) revisará las alertas de alta prioridad emitidas por las herramientas DLP y el SIEM para una respuesta rápida ante incidentes.
- Informes Mensuales de Cumplimiento: Se generarán reportes ejecutivos automatizados que analicen las métricas de rendimiento del sistema DLP, intentando identificar áreas de riesgo recurrente o necesidades de capacitación para los usuarios.
- Período de Retención de Logs: Los registros de auditoría de seguridad se almacenarán de forma cifrada durante un período mínimo de 12 meses, asegurando la trazabilidad requerida para auditorías externas y el cumplimiento estricto del GDPR.

5. Prevención de Filtraciones de Datos Sensibles

5.1. Marco Tecnológico de Prevención de Filtraciones

La prevención de filtraciones de datos sensibles abarca la implementación coordinada de salvaguardas tecnológicas y controles automatizados diseñados para impedir el robo, extracción, divulgación o pérdida no autorizada de la información confidencial de TechCorp Inc..

Dado que la empresa desarrolla soluciones de software para sectores altamente regulados (finanzas, atención médica y comercio electrónico) y está sujeta al cumplimiento de normativas como el GDPR, la estrategia de prevención se estructura en torno a dos pilares tecnológicos fundamentales: el cifrado criptográfico de datos y el despliegue de soluciones especializadas de Prevención de Pérdida de Datos (DLP) integradas en la infraestructura corporativa.

5.2. Mecanismos de Cifrado de Datos

El cifrado es el proceso de convertir la información en una forma codificada e ininteligible para evitar que personas o sistemas no autorizados accedan a su contenido. Para garantizar una protección continua, TechCorp Inc. aplica esquemas de cifrado en los diferentes estados de la información:



A. Cifrado de Datos en Reposo

Para resguardar los archivos almacenados en servidores, computadoras corporativas y servicios en la nube (como contratos de empleados, presupuestos, expedientes médicos e información de I+D):

- Endpoints Locales: Se exige el cifrado de disco completo con el estándar AES-256 utilizando BitLocker en sistemas Windows (integrado con el módulo TPM y Active Directory) y FileVault en sistemas macOS.
- Entornos de Nube: Para la infraestructura y almacenamiento alojados en la nube, se utiliza AWS Key Management Service (AWS KMS), garantizando un cifrado AES-256 agnóstico, con rotación automatizada de claves y cumplimiento con estándares como FIPS 140-2 y HIPAA.

B. Cifrado de Datos en Movimiento

Para asegurar la información que transita a través de redes internas o externas (como el intercambio de datos de facturación con proveedores o la gestión de proyectos con clientes):

- Comunicaciones Web e Internas: Implementación de protocolos SSL/TLS y HTTPS con cifrado fuerte basado en AES y certificados digitales.
- Transferencia Segura de Archivos: Canalización obligatoria de archivos sensibles mediante el protocolo SFTP utilizando clientes administrados como WinSCP.
- Acceso Remoto y Conexiones de Red: Uso de túneles IPsec VPN respaldados por dispositivos de seguridad perimetral como Cisco ASA y clientes de acceso Cisco AnyConnect o OpenVPN con algoritmos AES-256.

5.3. Herramientas DLP y Salvaguardas en Uso

La tecnología DLP extiende la prevención de filtraciones mediante la inspección profunda de contenido, el análisis contextual y la aplicación de reglas automatizadas en los endpoints de los 200 empleados de TechCorp Inc.:

A. Protección de Datos en Uso (Agentes de Endpoint)

Debido a que la información expuesta en memoria RAM o mostrada en pantalla se encuentra en su estado más vulnerable durante el procesamiento activo:

- Agentes Centinelas: Se despliegan agentes de software DLP (Symantec DLP, McAfee DLP Endpoint, Digital Guardian o Forcepoint DLP) en las estaciones de trabajo de los colaboradores.
- Restricción de Acciones: Los agentes bloquean o restringen de forma automática operaciones de copiar y pegar información etiquetada como sensible hacia aplicaciones no autorizadas o navegadores personales.
- Control Visual y Digital: Se habilitan funciones para bloquear capturas de pantalla e insertar marcas de agua dinámicas con la identidad del usuario sobre aplicaciones que despliegan propiedad intelectual o datos de clientes.
- Control de Dispositivos: Se restringe la copia de archivos corporativos hacia dispositivos de almacenamiento extraíbles USB no autorizados.

5.4. Integración de Controles en la Infraestructura Corporativa

Para prevenir la filtración de datos de manera uniforme, las soluciones DLP se integran directamente con la infraestructura existente de TechCorp Inc.:

- Integración de Red y Puertas de Enlace (Network DLP): Implementación de soluciones DLP en los puntos de entrada y salida de la red corporativa, trabajando en conjunto con firewalls perimetrales y servidores proxy para analizar el tráfico saliente y detener la exfiltración de información no autorizada.
- Integración en la Nube: Uso de conexiones basadas en API para vincular los sistemas DLP locales con los servicios y plataformas en la nube de la empresa, garantizando la aplicación homogénea de políticas de seguridad en entornos híbridos.
- Integración de Aplicaciones y Suites de Productividad: Incorporación de controles DLP nativos o de terceros en las suites de colaboración de la empresa (como Microsoft 365 o Google Workspace) y en las aplicaciones personalizadas desarrolladas en I+D.

6. Programa de Educación y Concienciación en Ciberseguridad

6.1. Objetivos Estratégicos del Programa

El elemento humano representa tanto el principal vector de vulnerabilidad como la primera línea de defensa (*human firewall*) en la estrategia de ciberseguridad de TechCorp Inc.. Con una fuerza laboral de 200 empleados distribuidos en cinco departamentos clave (Recursos Humanos, Finanzas, Investigación y Desarrollo, Soporte al Cliente, y Ventas y Marketing), el programa de educación y concientización busca institucionalizar una cultura organizacional centrada en la protección activa de la información.

Los objetivos específicos del programa abarcan:

- **Alineación Normativa:** Garantizar el conocimiento y cumplimiento estricto de la Política de Protección de Datos corporativa y el marco normativo internacional como el GDPR.
- **Reducción de Riesgos Operativos:** Minimizar los incidentes de exfiltración o pérdida accidental de datos en sus tres estados: en reposo, en movimiento y en uso.
- **Uso Correcto de Salvaguardas:** Capacitar al personal en la interacción diaria con los controles de cifrado, agentes DLP, autenticación multifactor (MFA) y canales de transmisión seguros.

6.2. Estructura de Capacitación Segmentada por Roles

Para asegurar la máxima efectividad, el plan de formación abandona los enfoques genéricos y adapta sus contenidos al nivel de responsabilidad y sensibilidad de los datos manejados por cada área:



A. Inducción General para Nuevos Empleados (*Onboarding*)

Todo colaborador recién ingresado debe completar obligatoriamente el módulo de inicio antes de recibir privilegios de acceso en la red corporativa:

- Revisión del Código de Conducta Laboral y compromiso con la Política de Protección de Datos.
- Introducción a las tres categorías de clasificación de información (Alta, Media y Baja sensibilidad) y manejo de activos.
- Buenas prácticas en el uso de credenciales en Active Directory / Azure AD u Okta.

B. Capacitación General y Continua para Todo el Personal

Dirigida semestralmente a los 200 empleados de la organización:

- Ingeniería Social y Phishing: Identificación de correos fraudulentos, enlaces sospechosos y manipulación psicológica.
- Higiene Digital y Trabajo Remoto: Políticas para el uso seguro de servicios en la nube, redes Wi-Fi corporativas o remotas y uso de clientes VPN (Cisco AnyConnect / OpenVPN).
- Pautas para Datos en Uso: Restricciones de copiar-pegar, uso de dispositivos extraíbles y concientización sobre marcas de agua dinámicas y bloqueo de capturas de pantalla.

C. Módulos de Capacitación Especializada por Departamento

- Investigación y Desarrollo (I+D): Formación en metodologías de desarrollo seguro, protección de repositorios de código en canales CI/CD, gestión de claves en AWS KMS y resguardo de la propiedad intelectual clasificada como ALTA.
- Finanzas y Recursos Humanos: Procedimientos para el manejo de nóminas, presupuestos y expedientes médicos/familiares. Cifrado obligatorio de endpoints con BitLocker o FileVault y uso de protocolo SFTP (WinSCP) para transferencias externas.
- Soporte al Cliente, Ventas y Marketing: Manejo seguro de listas de proyectos, datos de contacto de clientes e historiales de consultas, previniendo el robo o extracción de listados masivos mediante agentes DLP de endpoint.

6.3. Metodologías y Dinámicas de Concientización

Con el objetivo de mantener un alto nivel de alerta y aprendizaje práctico, TechCorp Inc. utilizará diversas metodologías interactivas:

- Simulaciones de Phishing no Anunciadas: Realización de ejercicios prácticos trimestrales mediante el envío de correos simulados de prueba. Los colaboradores que identifiquen y reporten el correo serán reconocidos; aquellos que caigan en la simulación recibirán entrenamiento de refuerzo inmediato de 15 minutos.
- Cursos de Micro-aprendizaje (Micro-learning): Cédulas de capacitación digital de 5 a 10 minutos con videos y cuestionarios breves enfocados en escenarios reales de trabajo (ej. qué hacer al enviar accidentalmente un archivo con datos financieros).

- Boletines de Seguridad y Campañas de Difusión: Emisión mensual de notas informativas por parte del área de Seguridad de la Información (CISO) sobre nuevas modalidades de ciberataques y consejos de seguridad.

6.4. Medición, Métricas e Indicadores de Rendimiento (KPIs)

Siguiendo las mejores prácticas de implementación DLP, el programa de concientización será revisado y actualizado periódicamente en función de métricas cuantificables:

- Tasa de Finalización de Capacitaciones: Meta del 95% de participación activa en los cursos obligatorios anuales.
- Métricas de Simulaciones de Phishing: Reducción de la tasa de clics en correos de prueba por debajo del 5% a nivel corporativo.
- Reducción de Incidentes DLP: Disminución en el número de alertas generadas por intentos de violación de políticas de datos en uso (como intentos de copiar-pegar o envíos externos no cifrados) registradas por los agentes DLP.
- Retroalimentación Continua: Ajuste periódico de los contenidos educativos según los hallazgos de las auditorías del sistema SIEM y las herramientas de clasificación de datos.

7. Conclusión

La implementación de la estrategia de Prevención de Pérdida de Datos (DLP) en TechCorp Inc. representa un pilar fundamental para garantizar la sostenibilidad operativa, la protección de la propiedad intelectual y la confianza de los clientes en sectores altamente regulados como finanzas, salud y comercio electrónico.

A través de la evaluación de la infraestructura y los flujos de información organizacionales, se destacan las siguientes conclusiones clave:

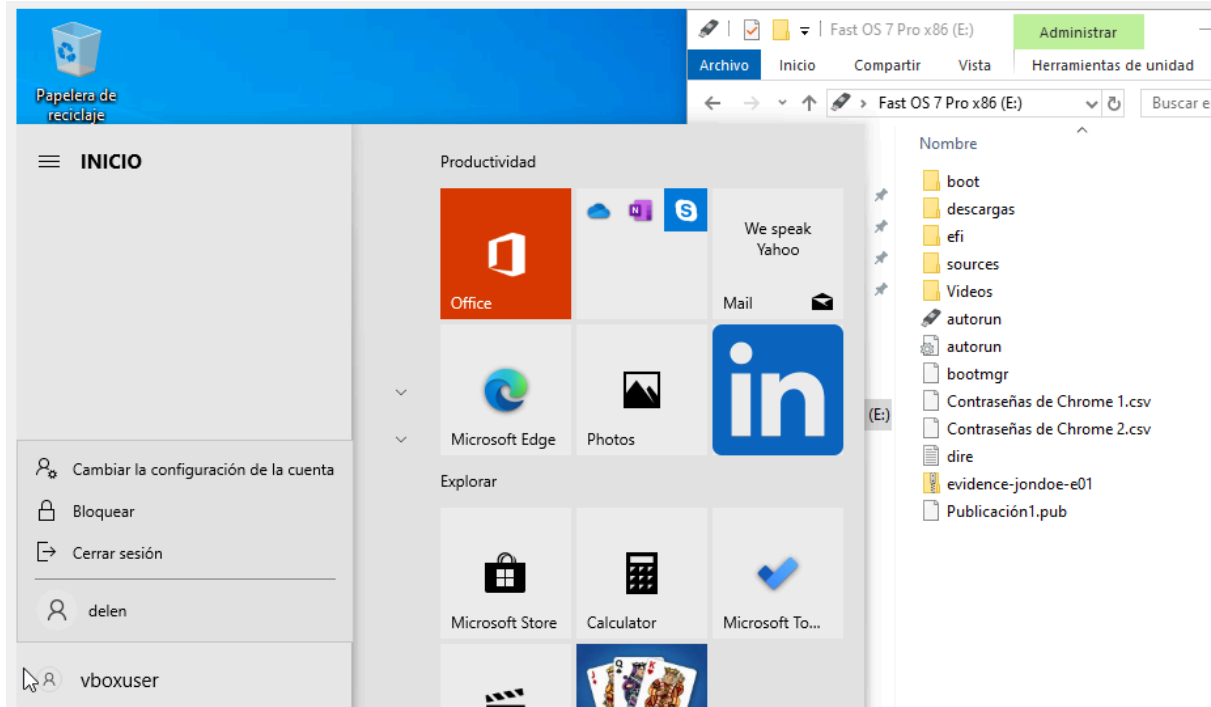
- **Protección Integral en los Tres Estados de la Información:** La combinación de mecanismos de cifrado avanzado (AES-256, BitLocker, FileVault, AWS KMS) y herramientas de inspección activa (Network DLP y Agentes de Endpoint) asegura la custodia de los activos de datos sensibles (Alta, Media y Baja sensibilidad), cubriendo eficazmente sus estados en reposo, en movimiento y en uso.
- **Control de Acceso Riguroso y Menor Privilegio:** La aplicación estricta del Principio del Menor Privilegio (PoLP) respaldada por arquitecturas de identidad unificada (Active Directory, Azure AD, Okta, AWS IAM) y auditorías trimestrales de permisos elimina la acumulación no autorizada de accesos y preserva el aislamiento departamental entre los 200 colaboradores de la empresa.
- **Visibilidad Centralizada y Cumplimiento Normativo:** La integración de agentes DLP y componentes de red con un sistema SIEM permite la correlación de eventos en tiempo real, garantizando la trazabilidad de los logs y el cumplimiento estricto con regulaciones internacionales de privacidad como el GDPR.
- **El Factor Humano como Primera Línea de Defensa:** La tecnología y los controles perimetrales se complementan con un programa continuo de capacitación segmentada por roles y simulaciones de phishing, transformando al personal en un firewall humano comprometido con la cultura de ciberseguridad.

En síntesis, la estrategia DLP propuesta no sólo mitigará el riesgo de filtraciones accidentales o maliciosas, sino que consolidará la reputación de TechCorp Inc. como un referente de excelencia, seguridad y responsabilidad en el desarrollo de software corporativo.

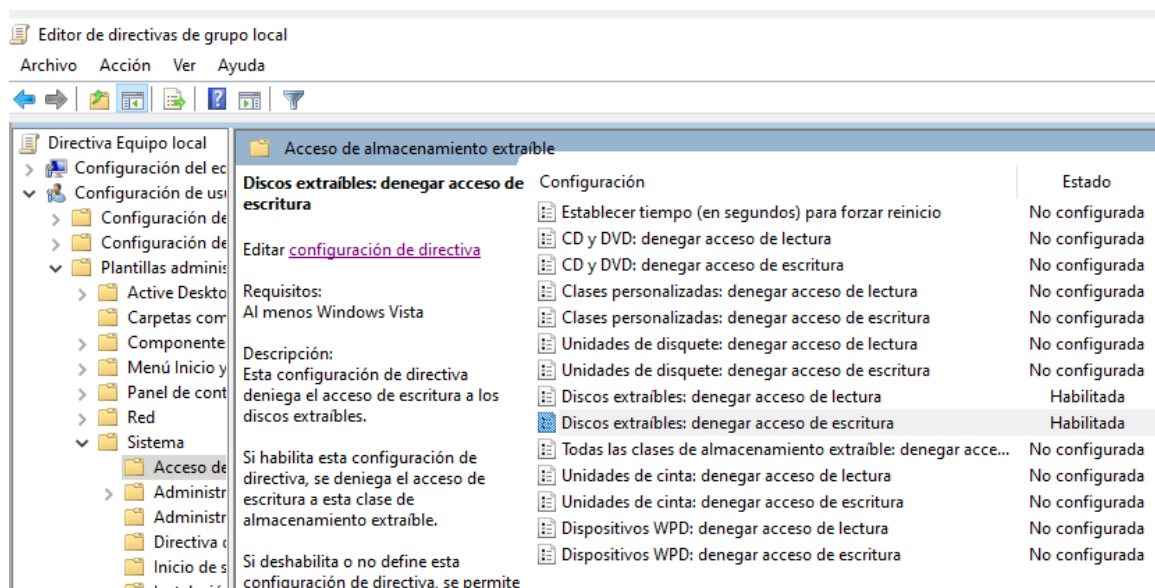
8. Pruebas de aplicación de Políticas de Seguridad DLP a dispositivos de almacenamiento externo

Se agregan imágenes de Políticas de Seguridad DLP a dispositivos de almacenamiento externo

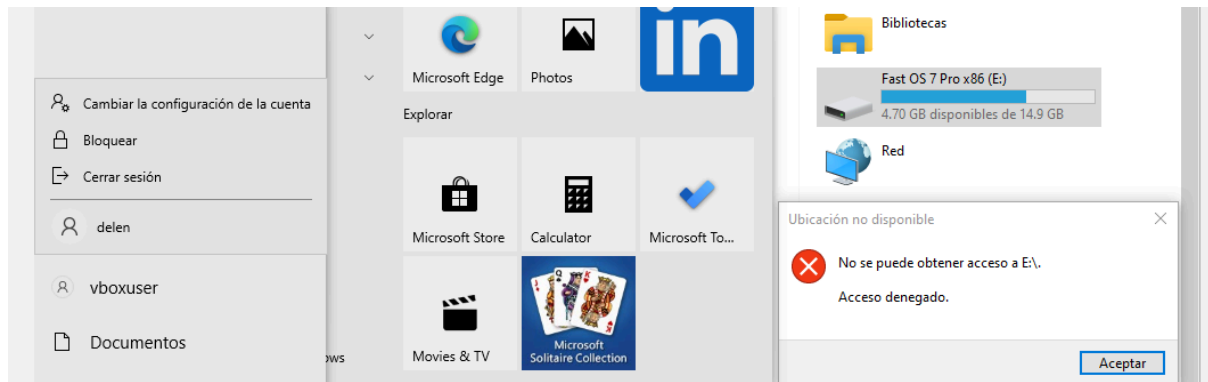
A. prueba de acceso a disco extraíble por cuenta principal administrador vboxuser



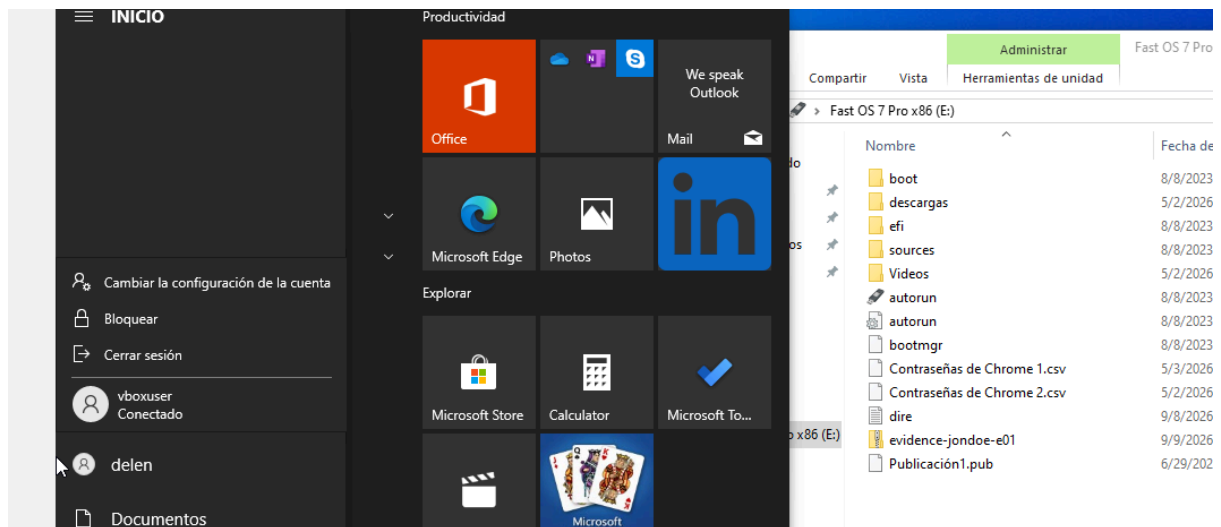
B. prueba de entrada a editor de directivas de grupo, con denegación de acceso de lectura y escritura en discos extraíbles habilitadas solo para el usuario principal vboxuser.



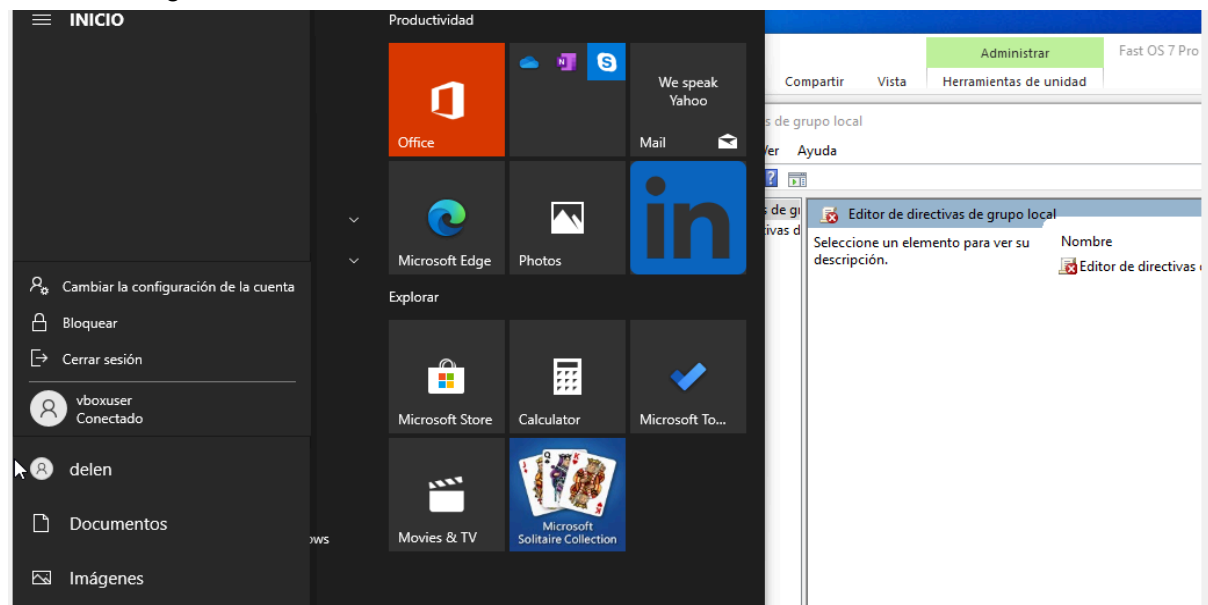
C. prueba de intento de lectura de discos extraíble negada en usuario vboxuser



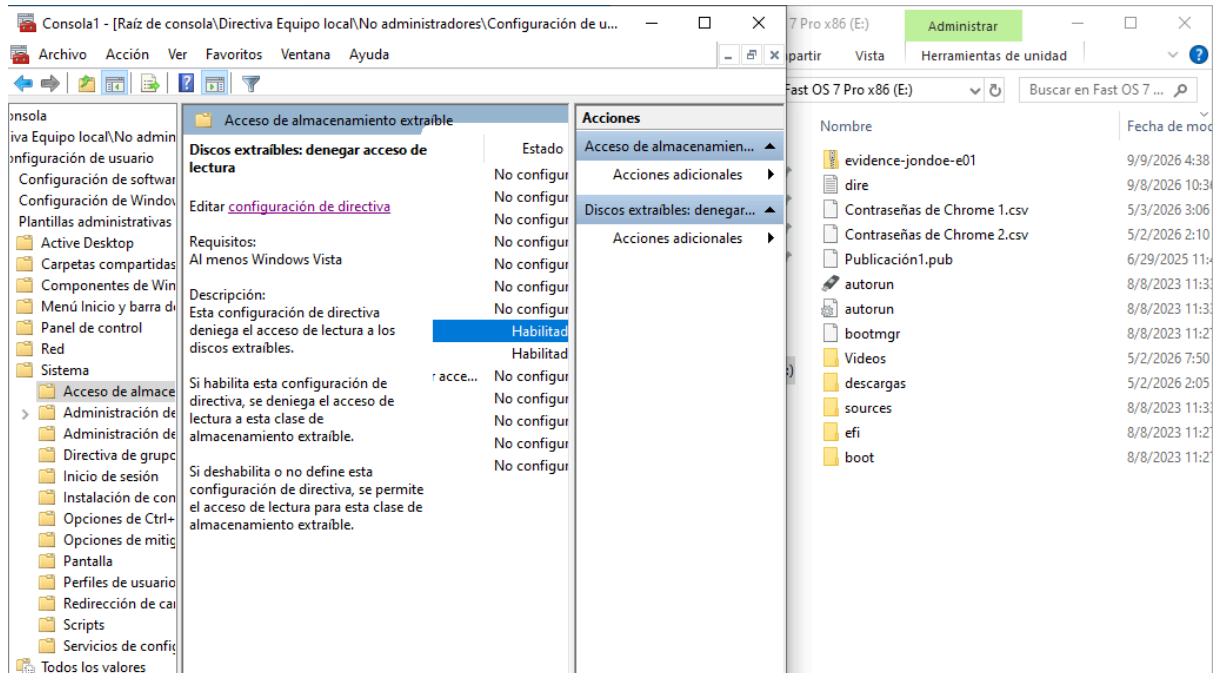
D. prueba de lectura disco extraíble para usuario familiar delen sin permisos de administrador, exitosa



E. prueba de intento de cambiar directivas en usuario no administrador, acceso denegado.



F. prueba de creación de grupo de directivas locales para el usuario delen desde usuario administrador que a su vez tiene acceso a lectura de discos extraíbles.



G. prueba de denegación de lectura de disco extraíble en usuario del deld

